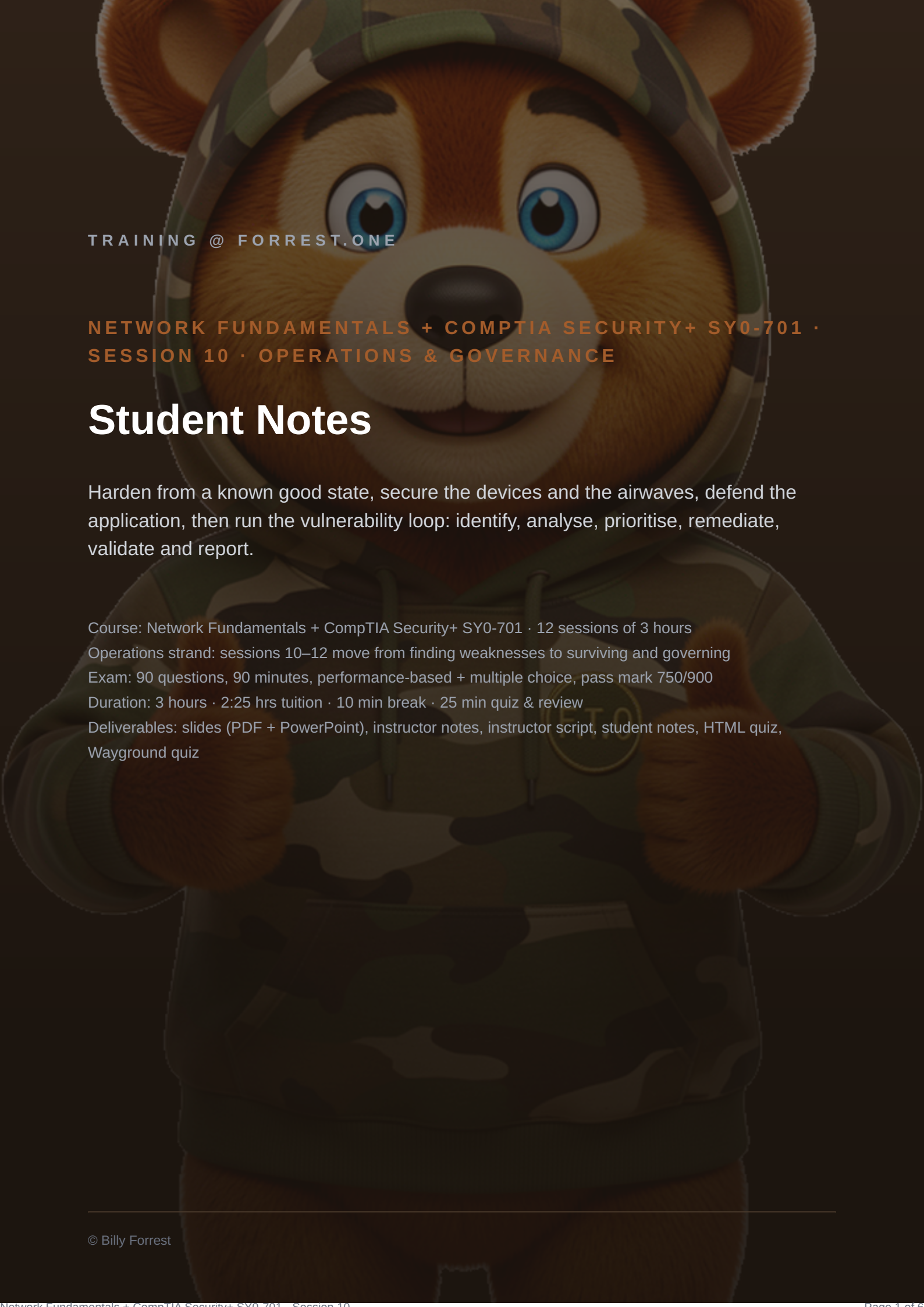




TRAINING @ FORREST.ONE

NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 10 · OPERATIONS & GOVERNANCE

Student Notes

Harden from a known good state, secure the devices and the airwaves, defend the application, then run the vulnerability loop: identify, analyse, prioritise, remediate, validate and report.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

Operations strand: sessions 10–12 move from finding weaknesses to surviving and governing

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Student Notes, Vulnerability Management & Asset Protection

Your revision guide for Session 10, arranged chapter by chapter in the order we taught it. Read it alongside the slides, then use the self-check questions and the session quiz to confirm you can run the vulnerability loop and account for every asset.

Key terms

Term	Definition
Secure baseline	The documented minimum security settings a system needs before deployment
Configuration drift	Divergence from the baseline, through unauthorised change or missed update
Ansible / Puppet / Chef / SaltStack	Configuration management tools that apply settings and report drift
Attack surface	Every point where an attacker can send or take data
Hardening	Shrinking the attack surface: services, ports, accounts, permissions
Secure boot	Refuses to load unauthorised firmware during start up
MDM	Mobile device management: policy, configuration, compliance checks, remote wipe
BYOD	Bring your own device: flexibility and lower cost, less control
Containerisation	Isolates work data so personal applications cannot reach it
WEP / WPA / WPA2 / WPA3	The four generations of wireless encryption, each replacing the failure before it
Pre-shared key	One passphrase shared by all users of a wireless network
RADIUS	Remote Authentication Dial-In User Service: per-user enterprise authentication
Rogue access point	Unauthorised wireless hardware on your premises
Site survey	Coverage planning that also sets security zones and stops at your walls
Input validation	Accept only known good data, sanitise the rest, enforce boundaries
Allow listing	Only pre-approved applications may run: list the good, not every bad
Sandboxing	Runs code isolated with limited access to system resources
Code signing	A signature proving software origin and integrity

Term	Definition
WAF	Web application firewall: filters and monitors traffic to the application
RASP	Runtime application self-protection: watches behaviour and blocks live attacks
Credentialed scan	A scan using valid credentials, which sees internal state and missing patches
CVE	Common Vulnerabilities and Exposures: the identifier for a known flaw
CVSS metric groups	Base (the flaw), temporal (exploit and fix state), environmental (your asset)
False positive	A reported vulnerability that does not exist; validate before acting
Compensating control	Extra monitoring or detection where a direct fix is impossible
Risk acceptance	A documented, reviewed decision to live with a known risk
Asset owner	Accountable for the asset and how it may be used
Custodian	Day to day: updates, access control and the asset record
Data sanitisation	Overwriting, degaussing, physical destruction or cryptoshredding
Chain of custody	Unique identifier, every transfer, and the disposal record
SIEM	Aggregates and correlates logs from many sources to reveal patterns
UEBA	User and entity behaviour analytics: baseline normal, flag deviation
Alert fatigue	So many alerts that the one that mattered is missed

Core concepts

1 • Baselines and hardening

A secure baseline is the documented minimum configuration a system must have before deployment, and configuration drift is the quiet divergence that follows. Implementation is four steps: identify the requirements, develop the configuration, test it in a controlled environment, deploy and monitor for drift. Sources include the Centre for Internet Security Benchmarks and vendor hardening guides. Configuration management tools hold the standard at scale: Ansible with readable text files, Puppet with a declarative language, Chef with a domain specific language on Ruby, SaltStack with a master and minion architecture. Hardening reduces the attack surface by auditing services, closing unused ports, removing or securing default accounts and enforcing least privilege, at three layers: operating system (patching, disabled services, mandatory access control), application (secure configuration, updates, validation) and firmware (current versions, secure boot). Balance matters: over-hardening breaks processes and gets rolled back, so assess impact, test, document and review.

2 • Mobile devices and wireless

Mobile devices are lost and stolen, they run many security models, they install unvetted third party applications, and they roam onto public Wi-Fi. Mobile device management answers with central control:

policy, configuration, compliance checks and remote wipe. BYOD buys flexibility and costs control; corporate owned devices buy control and cost freedom; containerisation isolates work data either way; application vetting decides what may be installed. Wireless encryption has four generations: WEP (RC4 with a weak integrity check, broken), WPA (Temporal Key Integrity Protocol, a key per packet, still RC4), WPA2 (Advanced Encryption Standard, pre-shared key or enterprise), and WPA3 (Simultaneous Authentication of Equals, which resists offline guessing and adds forward secrecy). A pre-shared key is one passphrase for everybody; enterprise authentication checks each credential at a RADIUS server. Detect rogue access points by scanning the spectrum, and use the site survey to set coverage and security zones.

3 • Applications and monitoring

Application security begins in the code: least privilege, correct error handling, code review, input validation and boundary checking, with allow listing preferred over blocklisting. The defences around the application are a web application firewall for internet facing services, sandboxing for untrusted content, allow listing for servers, code signing for distribution and runtime self-protection in production. Layer them to cover prevent, contain, verify and detect. Monitoring is continuous observation: watch authentication attempts, privilege usage, network traffic and system change, because you cannot spot abnormal until you know normal. Real-time alerting catches the active threat, trend analysis reveals the campaign, and scope sets both your storage requirement and your detection ceiling. Too many alerts hide the one that mattered.

4 • The asset lifecycle

Asset management starts at the purchase order, with security requirements in procurement, vendor assessment and supply chain verification, which defends against a malicious change during manufacture or delivery. In service, the owner is accountable and the custodian does the daily work, and both depend on an accurate inventory, because the first question after a compromise is what else touched the asset. Tracking is continuous: location for the devices that move, configuration, patch state, licence counts and unauthorised installations. Disposal is a security process: overwriting for reused media, degaussing for magnetic media only (it does nothing for flash), physical destruction for end of life hardware, and verification every time. Chain of custody records each transfer and the disposal, and the GDPR and HIPAA raise the stakes on personal and health data.

5 • Vulnerability management

The loop is identify, analyse, prioritise, remediate, validate, report, and it never closes. Network scanners see the infrastructure, host scanners see one device in depth, application scanners test the web application, and none of them finds a design flaw. A credentialed scan sees missing patches and misconfiguration from inside; a non-credentialed scan sees only what an outsider sees. CVSS scores from three metric groups: base (the flaw itself, fixed), temporal (exploit and fix availability, report confidence) and environmental (how much the asset matters to you). Priority then depends on criticality, exposure, exploitability and validation of suspected false positives, because exposure and active exploitation outrank the raw score. Remediation offers four options: patch, configuration change, compensating control, or documented risk acceptance with an owner and a date. Rescan to confirm the fix, keep exceptions visible, and report counts by severity, average time to patch and trends, with responsible disclosure to the vendor and written rules of engagement for any test.

6 · Monitoring tools and technologies

Every control produces logs, and logs alone change nothing. A SIEM aggregates and correlates logs from many sources, so an event that looks harmless in one log is obvious across three. A log management platform provides collection, storage and retention for investigations and regulators. Network traffic analysis captures packets, catching exfiltration and floods. File integrity monitoring compares critical files against a baseline, exposing tampering and persistence. User and entity behaviour analytics learn normal behaviour and flag deviation, then risk score findings so investigations start where behaviour is strangest. Dashboards carry few metrics drawn clearly, and alert tuning keeps false positives from crowding out real ones.

Practical cautions

- Do not treat a baseline as a one-off project; holding the configuration there is continuous work.
- Do not harden without assessing operational impact; a broken control gets switched off quietly.
- Do not rely on secure boot alone for firmware; keep firmware versions current as well.
- Do not share one pre-shared key across a large wireless estate; use enterprise authentication.
- Do not expect WPA2 to resist offline guessing; that is what the WPA3 handshake adds.
- Do not blocklist input; allow listing names what is permitted and refuses the rest.
- Do not treat a sandbox as a fix; it contains what runs, it does not make code safe.
- Do not treat CVSS score as risk; criticality, exposure and exploitability decide priority.
- Do not remediate a suspected false positive without validating it first.
- Do not rely on non-credentialed scans alone; credentialed scans see missing patches.
- Do not assume a wider scan scope is free; it sets your storage bill and detection ceiling.
- Do not degauss flash media; use overwriting, cryptographic erasure or destruction instead.
- Do not discard hardware without verified destruction and chain of custody records.
- Do not leave alerts untuned; noise hides the alert that mattered.

Self-check questions

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz. The quiz shows the session area for every question, so a low score tells you exactly which slides to revisit.

Exam tips for Session 10

- The loop order, identify, analyse, prioritise, remediate, validate, report, is directly examinable.
- Baseline and drift, and the four implementation steps, appear in process questions.
- Hardening is attack-surface reduction: fewer services, ports, accounts and permissions.
- The three hardening layers and secure boot are a frequent separation question.

- Credentialed versus non-credentialed scanning is a classic comparison.
- CVSS base, temporal and environmental metric groups are commonly tested.
- Severity is not risk: criticality, exposure and exploitability set priority.
- Remediation options run patch, configure, compensate, accept, with a documented owner and date.
- WEP, WPA, WPA2 and WPA3 in order, with the WPA3 handshake, is a favourite sequence.
- Mobile device management, containerisation and application vetting answer mobile scenarios.
- Data sanitisation method matching is common: overwrite, degauss, destroy, cryptoshred.
- Verification and chain of custody are the compliance half of disposal.
- SIEM correlation, log retention and alert fatigue answer monitoring tooling questions.

Further reading

- Centre for Internet Security Benchmarks: baseline configuration guidance.
- FIRST: the CVSS specification, including temporal and environmental metrics.
- MITRE: the CVE list; NIST: the National Vulnerability Database.
- NIST SP 800-40: enterprise patch management planning.
- NIST SP 800-124: guidelines for managing the security of mobile devices.
- NIST SP 800-88: media sanitisation guidelines.